

RESOLUTION OF SANCTIONING PROCEDURE

From the procedure instructed by the Spanish Agency for Data Protection and based on the following:

BACKGROUND

FIRST: Mr. A.A.A. (hereinafter, the claimant) filed a complaint with the Spanish Agency for Data Protection on March 21, 2023. The complaint is directed against TELEFÓNICA MÓVILES ESPAÑA, S.A.U. with NIF A78923125 (hereinafter, the respondent or "TME"). The reasons for the complaint are as follows:

The claimant states that on January 7, 2023, at around 5:00 PM, his "Movistar" mobile phone stopped working, which he did not give much importance to as he attributed it to a possible damage to his phone's SIM card. He adds that on January 9 of the same month and year, he went to a "Movistar" store to obtain another SIM card and at that moment he recovered his phone line.

In this context, he notes that on January 16, 2023, he checked his bank application and found that six banking transactions had been made by a third party between January 7 and 9, 2023.

Subsequently, on January 17, "TME" informed him that on January 7, 2023, a duplicate of the claimant's SIM card was issued and delivered to a third party.

He provides the following relevant documentation:

- Complaint made to "TME", dated January 25, 2023.
- Report to the National Police Commissioner Madrid-Retiro.
- Bank statements.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), the complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The transfer, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on May 16, 2023, as recorded in the acknowledgment of receipt in the file.

On June 16, 2023, this Agency received a response indicating:

"As will be evidenced through the arguments presented throughout this document, this party understands that the situation giving rise to the complaint filed by the claimant does not stem from inadequate compliance with the requirements of data protection regulations by Telefónica, but rather from fraudulent actions committed maliciously by a third party with the intent to unlawfully profit at the expense of the claimant.

Regarding the reported facts, Telefónica informs that there is a request for a change of ICC of the claimant's SIM card on January 7, 2023, at 5:53 PM through one of our Points of Sale.

On January 9, 2023, as explained by the claimant in his complaint, another change of ICC was requested. This request was made at another Telefónica Point of Sale.

In this regard, when a customer requests a duplicate of a SIM card at a Movistar store, the procedure to be followed is the so-called "SIM Card Change," which for individual customers of the Movistar brand, as in this case, consists of the following: In the case of individuals, the person authorized to carry out the management would be the holder of the line for which the duplicate is requested, or a legal representative or authorized person by the holder. For a higher degree of protection regarding the verification of the customer's identity, a double control is established:

- Customer identification, understood as the demonstration or recognition of the identity of the person both verbally (when the customer provides their ID number) and visually (when the customer presents their identity document, which entails a higher level of security).
- Customer validation, which can be carried out in two ways (indicating that if the QR code validation method is available, this will be the preferred way to do so):
 - Customer Identity Verification System or "SVIC," also known as "identity document scanner": involves the following actions:
 - Verify that the identity documentation provided by the customer is authentic and valid (to prevent

identity theft);

- Record this verification in the systems (to document that the customer has been in the store and has been identified with that documentation).
- QR Code: Within the "My Movistar" App, there is a section called "In-store Identification."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

2/22

3/22

When the client visits the store to request a duplicate card, the sales agent will ask them to access that section. To gain access, it is essential that the user knows the username and password associated with the line. At that moment, a QR code will be automatically generated that the sales agent can read with a barcode scanner. In this way, the client's information (client file) will appear directly on the computer screen of the agent attending to them.

In the case of a legal representative or another authorized person, it will be necessary to provide the following documentation according to the status of the individual acting on behalf of the holder (authorized person or legal representative): identification document of the authorized person or legal representative; authorization or documentary accreditation of the status of legal representative or power of attorney; photocopy of the identification document of the holder.

The authorization, which may be printed or received in the store by email, must contain the following information:

- Full name and NIF of the line holder.
- Authorization to the person who goes to the point of sale (indicating the full name and NIF).
- Mention of the corresponding operation (specifically, so that it is not understood to authorize more than what is specified).
- Signature of the authorizing person (holder).

Finally, the process concludes with the signing of the "SIM card change contract," and the delivery of the card in hand.

This contract details the reason for the change, the point of sale where it has been processed, and the identifying data of the client and the card.

THIRD: On June 20, 2023, in accordance with Article 65 of the LOPDGDD, the complaint submitted by the claimant was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to the control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions established in Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

In the case of the duplicate SIM card of the claimant, the representatives of the entity allege that upon reviewing their systems, there is no documentation stored for the request to change the ICC dated January 7, 2023.

However, the request dated January 9, 2023, is recorded, of which a copy is attached. This request is the one that the claimant states they made to recover their line.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/22

FIFTH: According to the report obtained from the AXESOR tool, the entity TELEFÓNICA MÓVILES ESPAÑA, S.A.U. is a large company established in 1988, with a turnover of 4,406,624,000 euros in 2022.

SIXTH: On December 4, 2023, the Director of the Spanish Agency for Data Protection agreed to

initiate sanctioning proceedings against the respondent, in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR.

SEVENTH: Once the aforementioned initiation agreement was notified in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the respondent requested an extension of the deadline to submit allegations and on January 3, 2024, submitted a written statement of allegations in which, in summary, it stated: << this party requests the Agency to suspend the sanctioning procedure and require the Claimant to provide information regarding the status of the complaint filed, as well as the content of any criminal proceedings that may be underway, and, if necessary, to agree to suspend this procedure due to criminal prejudiciality given the close relationship that, as this party already anticipates, is likely to exist between the criminal and administrative procedures.

It should be noted that, from the responses made by this party to the information requests made by the Agency, it cannot be inferred that they imply an admission, presumption, or verification by the Agency that the commercial agent did not follow the procedures related to customer identification. That is to say, while the copy of the request made at the physical store has not been recorded in the systems, it cannot be demonstrated that the agent did not follow the rest of the established procedures regarding customer identification. Therefore, there is no evidence of sufficient weight to undermine the presumption of innocence of Telefónica that proves the absence of verification of the identity of the person who requested the duplicate SIM card, nor to prove the absence of application of the precautions provided for cases like the one at hand.

The absence of a copy of the contract does not equate to the identification not being carried out correctly.

Due to the volume of operations of Telefónica and in order to ensure compliance with its obligations as a telecommunications operator, as well as to provide services correctly, Telefónica relies on several trusted suppliers for service provision. Both in the contracts signed with suppliers of the physical channel and those signed with suppliers of the telephone channel, Telefónica imposes a series of obligations that govern the relationship between Telefónica and these suppliers, as well as the importance that Telefónica places on compliance with the obligations established in data protection regulations and, in particular, on the correct identification of customers. Therefore, in any case, Telefónica cannot be considered responsible for the specific and exceptional non-compliances.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/22

operational activities that may have been carried out by the personnel contracted by the data controllers involved in this type of processes.

For the reasons stated, we understand that there is no basis for attributing to my client a violation of Article 6.1 of the GDPR, as the processing of such data by Telefónica is necessary to manage the contractual relationship with the Claimant and, therefore, Telefónica had sufficient legal grounds, thus the typical action does not apply, and the present sanctioning file should be archived.

If the impersonator has used the Claimant's data to request the SIM card, this party, unaware of such wrongdoing, manages the customer's request based on the execution of the contract it has signed with Telefónica.

In this regard, this party wishes to point out that considering the facts subject to the procedure as unlawful implies qualifying them based on the outcome of acts of deception, manipulation, and unlawful use of data, carried out by the potential banking fraudster who may have impersonated the identity of the claimant, not by the actions of my client.

Telefónica has established technical and organizational measures that are appropriate to ensure adequate security of its customers' personal data, including protection against unauthorized or unlawful processing. Furthermore, these measures are reviewed and updated when necessary to

ensure the security of the processing of customers' personal data and compliance with the requirements set forth in the GDPR.

All of the above only serves to demonstrate that the conduct followed by Telefónica can in no case be considered typical, given that the conduct carried out by Telefónica is not subsumable under the provision whose violation is alleged.

Moreover, it cannot be considered unlawful either. Telefónica believes that it has acted at all times in good faith and with a founded belief excluding any culpability. It is worth noting that the unlawfulness of the conduct, a constitutive element of any administrative offense, requires in its formal aspect that there is an opposition between the behavior and the violated norm.

In any case, the requirement of culpability in the actions of my client is also not met. Or, in other words, there is no subjective element of fault required for the imposition of administrative sanctions.

Telefónica's attitude reveals an unequivocal willingness to proceed and act in accordance with the law, with no intentionality whatsoever to violate the norm and with a will to comply in any case. Therefore, even if the Agency considers that there has indeed been unlawful data processing by this party, considering that Telefónica's action is typical and unlawful, it can in no case be asserted that the conduct followed by Telefónica can be considered culpable.

In this regard, it should be taken into account that the management of the duplicate SIM would have been carried out in any case as a result of acts of deception, manipulation, and unlawful use of data by a third party, who would have deceived our commercial representative into believing that they were the person holding the data or that

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/22

had their consent to make the request as they had correctly identified themselves with the customer data that appears in our systems.

Therefore, in any case, Telefónica's conduct could never be considered culpable, as this situation presents an invincible error. An error of type occurs when a subject commits a crime without knowing the elements of the objective type, whether regarding the facts that constitute it or the aggravating circumstances thereof or that qualify it.

In this case, where according to the procedure, the customer would have identified themselves with the correct data for the request for a duplicate SIM card, it is established that we would be facing an invincible error, where the unlawfulness of the conduct was unknown, and the procedure should be archived, as Telefónica's culpability cannot be determined.

Without prejudice to the preceding allegations regarding the absence of typicity, unlawfulness, and culpability, and in case the Agency does not agree to archive this sanctioning file, subsidiarily, this party wishes to express its disagreement with the amount of the proposed sanction in the Agreement, which is clearly disproportionate when considering the following aspects:

- When it states as a circumstance to aggravate the sanction the nature, severity, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damages they have suffered.

Well, if we consider the specific case and the responsibility of Telefónica, we are talking about an individual case of a request for a duplicate SIM card in which the customer, in any case, has had their telecommunications service affected for two days.

Finally, the Agency also takes into account the circumstance of Article 83 2.e) GDPR, expressly mentioning the sanctioning procedures EXP202207989 and EXP202211479: "Any previous infringement committed by the data controller or the processor."

In this regard, and as long as the Courts of Justice are resolving on this matter and there is no definitive ruling on the same, this party considers that this aggravating circumstance should not be appreciated. Otherwise, if the appeal presented is upheld, it would cause enormous harm to this party. Telefónica is completely consistent with the position taken by the Agency when, in similar cases of SIM swapping as in the two mentioned files, it states that there is no violation of the principle of non bis in

idem in the imposition of both sanctions separately, with the following argument in the sanctioning resolution of the sanctioning file EXP202211479, issued on June 13, 2023, by the Agency in a case of SIM swapping similar to the one currently being discussed here.

Therefore, considering the above, in this case, this aggravating circumstance should not be appreciated as it questions facts that, according to the Agency, would not be

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

7/22

similar cases. Consequently, the amount of the sanction must be adjusted to the specific individual case.

For all the reasons stated, in the event that the Agency decides to maintain the sanction, despite the arguments put forth by this party, these mitigating factors must be taken into account for a considerable reduction of the amount.

In this regard, it is important to highlight that the Agency's actions regarding a case related to facts substantially similar to those being claimed here have been contradictory, as the Agency itself informed us in the file with reference No. EXP202104446 dated January 26, 2022, in which it was decided to archive the case on the grounds that there was already an ongoing sanctioning file for the same facts, the literal wording of which was as follows: "On this particular matter, it should be emphasized that similar facts to those being claimed have been investigated by this Agency and sanctioned in the sanctioning procedure PS/00021/2021, processed against the claimed party, by resolution dated 11/08/2021, therefore, the initiation of a new sanctioning procedure is not appropriate."

Consequently, the discrepancy in administrative actions between one file and another would clearly violate the doctrine of one's own acts, creating palpable legal uncertainty and, therefore, would constitute the grounds for annulment of the Agreement as provided in Article 48.1 of Law 39/2015 of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, "Law 39/2015").

Furthermore, it should be noted that Telefónica has already been sanctioned for the same facts that are currently being addressed in this procedure; the Agency imposed the sanction through the procedure with reference PS/00021/2021, and as the Agency is aware, the corresponding appeal has currently been filed before the Courts of Justice. This leads us to consider that initiating a new sanctioning procedure, successively, without a ruling from the Courts of Justice on the same facts, violates the principle of non bis in idem. As is well known, the principle of non bis in idem prohibits punishing the same unlawful act twice, as doing so would entail judging and evaluating the same matter from a legal standpoint. In the opinion of this party, this is what the Agency intends in the Agreement, where it seeks to punish "the same": the punishment falls on the same subject, for the same act, and supposedly to protect the same legal interest.

For all the reasons stated, I REQUEST THE AGENCY to accept this Written Statement of Allegations as presented in due time and form, and, following the appropriate procedures, to: i. Declare the non-existence of responsibility on the part of Telefónica for the alleged infringement attributed to it in this procedure, ordering the archiving of the present sanctioning file. ii. Alternatively, in the event that the archiving of the present sanctioning file does not proceed, suspend the present procedure and require the claimant to provide information on the status of the filed complaint, as well as the content of any ongoing criminal proceedings, in order to determine if there is any criminal prejudiciality. iii. Finally, in case none of the above are accepted,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/22

previous claims, that the initially proposed sanction be reduced in light of the mitigating factors

stipulated in Article 83 of the GDPR>>.

EIGHTH: On January 15, 2024, the instructor of the procedure agreed to carry out the following evidence: <<1. The complaint filed by Mr. A.A.A. and its documentation, the documents obtained and generated during the admission phase of the complaint, and the report of preliminary investigative actions that are part of the procedure AI/00230/2023 are considered reproduced for evidentiary purposes. 2. Likewise, the allegations to the initiation agreement of the referenced sanctioning procedure, submitted by TELEFÓNICA MÓVILES ESPAÑA, S.A.U., and the accompanying documentation are considered reproduced for evidentiary purposes>>.

NINTH: On February 12, 2024, the resolution proposal was made, proposing that the Director of the Spanish Agency for Data Protection sanction the respondent for an infringement of Article 6.1 of the GDPR, classified under Article 83.5 of the GDPR, with a fine of 200,000 euros.

TENTH: After the proposal for resolution was notified, on February 19, 2024, the respondent did not submit any written allegations.

From the actions carried out in this procedure and the documentation in the file, the following have been established:

PROVEN FACTS

FIRST. It is recorded that TME on January 7, 2023, issued and delivered a duplicate of the claimant's SIM card to a third party.

Thus, "TME" acknowledges in its response dated June 16, 2023, to the information request from this Agency: <>.

SECOND. – "TME" acknowledges in its response dated August 29, 2023, that it does not have the documentation related to the ICC change of the claimant's SIM card dated January 7, 2023.

LEGAL GROUNDS

I

Competence

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the guarantee of digital rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic law, by the regulatory provisions issued in its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Criminal Prejudice

Prior to proceeding, it is necessary to resolve the allegation presented by "TME," based on the existence of criminal prejudice.

It is stated regarding these facts that they are currently subject to a criminal investigation. It is considered that, therefore, in application of the principle of criminal prejudice established in Article 10 of the Organic Law of the Judiciary, the matter should not be resolved administratively until it is resolved through criminal proceedings. This, it is stated, given that the proven facts will bind the Agency regarding a possible sanctioning procedure, in accordance with the provisions of Article 77.4 of Law 39/2015, of October 1.

It should be noted that Article 77.4 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP): "In sanctioning procedures, the facts declared proven by final criminal judicial resolutions will bind Public Administrations regarding the sanctioning procedures they process." However, it should be indicated that in the present case there is no triple identity necessary to apply Article 77 of the LPACAP (of subject, fact, and basis), between the administrative infringement being assessed and the possible criminal infringement or infringements that could arise from the alleged Preliminary Proceedings carried out by a judicial body. This is because:

- The infringing subject is obviously not the same – regarding the infringements of the LOPDGDD, the

responsible party is Telefónica, while the criminally responsible party for a potential crime of identity theft or fraud would be the third party who impersonated the claimant.

- Nor would the legal basis be the same: while the legal right protected by the LOPDGDD is the fundamental right to the protection of personal data, the legal right protected in the criminal offenses whose commission would be investigated, if applicable, by the Investigating Court would be civil status, property, etc.

In this regard, the Judgment of the National Court of April 27, 2012 (rec. 78/2010) is very enlightening, in which the Court states in its Second Legal Ground the following terms against the appellant's allegation that the AEPD has violated Article 7 of R.D. 1398/1993 (a regulation that was in force until the entry into force of the LPACAP): "In this regard, Article 7 of Royal Decree 1398/1993, of August 4, on the procedure for the exercise of the power...

10/22

The sanctioning authority only provides for the suspension of the administrative procedure when the effective and real existence of a criminal procedure is verified, if it is deemed that there is identity of subject, fact, and legal basis between the administrative infringement and the corresponding criminal infringement.

However, for the concurrence of a criminal prejudiciality, it is required that this directly conditions the decision to be made or that it is essential for resolution, conditions that do not occur in the examined case, in which there is a separation between the facts for which sanction is imposed in the resolution now appealed and those that the appellant invokes as possible criminal offenses. Thus, even if criminal proceedings were initiated in this case against the distributing company for the facts now in dispute, the truth is that both the sanctioning conduct and the legal interest protected are different in each avenue (contentious-administrative and criminal). In the criminal sphere, the protected legal interest is a possible document falsification and fraud, whereas in the administrative sphere, it is the right of the data subject to control their personal data, which is why such an objection from the defendant must be rejected.

In consideration of the above, the issue raised by the defendant cannot prosper and must be rejected.

III

Response to the allegations

Regarding the responsibility of "TME," it should be indicated that, in general terms, "TME" processes its customers' data under the provisions of Article 6.1 b) of the GDPR, as it is considered necessary for the execution of a contract in which the data subject is a party or for the application at their request of pre-contractual measures. In other cases, it bases the lawfulness of the processing on the grounds provided in Article 6.1.a), c), e), and f) of the GDPR.

For this reason, this is a process where the diligence provided by the operators is fundamental to avoid this type of fraud and violations of the GDPR. Diligence that translates into the establishment of appropriate measures to ensure that the person contracting is who they claim to be and that appropriate measures are implemented and maintained to comply with the principle of lawfulness.

In this line, the recent Judgment of the National Court of March 1, 2024 (rec. 1757/2021) states:

"Thus, the data controller is required to verify the accuracy of the data of the data subject through the implementation of appropriate measures when a contract is made. Precisely for this reason, it is necessary to ensure that the person contracting is who they really claim to be, and adequate preventive measures must be adopted to verify the identity of a person whose personal data is going to be processed, and this is why the requirement for identifying documentation is necessary, as the Chamber has reiterated in other judgments such as those of October 3, 2013 (Rec. 5472012), November 21, 2014 (Rec. 45/2014), etc."

The Constitutional Court stated in its Judgment 94/1998, of May 4, that we...

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/22

we find before a fundamental right to data protection, which guarantees individuals control over their

data, any personal data, and over its use and destination, to prevent the illicit trafficking of such data or harm to the dignity and rights of those affected; in this way, the right to data protection is configured as a power of the citizen to oppose the use of certain personal data for purposes other than those that justified its collection.

For its part, in Judgment 292/2000, of November 30, it considers it an autonomous and independent right that consists of a power of disposition and control over personal data that empowers the individual to decide which of those data to provide to a third party, whether the State or a private individual, or which data this third party may collect, and that also allows the individual to know who possesses that personal data and for what purpose, being able to oppose such possession or use. Regarding the conduct of "TME," it is considered to respond to the title of fault. As a large-scale holder of personal data, therefore, accustomed or specifically dedicated to managing the personal data of clients, it must be especially diligent and careful in its processing. That is to say, from the perspective of culpability, we are faced with a remediable error, since with the application of appropriate technical and organizational measures, these identity thefts could have been avoided.

It is Recital 74 of the GDPR that states: The responsibility of the data controller must be established for any processing of personal data carried out by themselves or on their behalf. In particular, the controller must be obliged to apply appropriate and effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing as well as the risk to the rights and freedoms of natural persons. Likewise, Recital 79 states: The protection of the rights and freedoms of data subjects, as well as the responsibility of controllers and processors, also with respect to the supervision by the supervisory authorities and the measures adopted by them, requires a clear attribution of responsibilities under this Regulation, including cases where a controller determines the purposes and means of processing jointly with other controllers, or where processing is carried out on behalf of a controller.

The respondent has requested in its written allegations, in a subsidiary manner, that this Agency agree to file the procedure due to the absence of fault.

Well, objective responsibility is prohibited in our legal system. The principle of culpability governs in sanctioning Administrative Law (Article 28 of Law 40/2015, on the Legal Regime of the Public Sector, hereinafter LRJSP), so the subjective or culpability element is an indispensable condition for the emergence of sanctioning responsibility. Article 28 of the LRJSP, "Responsibility," states:

"1. Only individuals and legal entities may be sanctioned for acts constituting an administrative infraction, as well as, when a Law provides for them..."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/22

recognize the capacity to act, the groups of affected parties, the unions and entities without legal personality, and the independent or autonomous assets, which are responsible for the same on the grounds of intent or negligence."

In light of this provision, liability can be imposed on the basis of intent or negligence, with mere failure to observe the duty of care being sufficient in the latter case.

To this end, it is necessary to bring to mind the Judgment of the Court of Justice of the European Union, dated December 5, 2023, in case C-807/21 (Deutsche Wohnen), which states:

"76 In this regard, it should also be specified, concerning the issue of whether an infringement has been committed intentionally or negligently and, therefore, can be sanctioned with an administrative fine under Article 83 of the GDPR, that a data controller can be sanctioned for behavior falling within the scope of the GDPR when they could not ignore the infringing nature of their conduct, whether or not they were aware of violating the provisions of the GDPR (see, by analogy, the judgments of June 18, 2013, Schenker & Co. and others, C-681/11, EU:C:2013:404, paragraph 37 and cited case law; of March 25, 2021, Lundbeck/Commission, C-591/16 P, EU:C:2021:243, paragraph 156, and of March

25, 2021, Arrow Group and Arrow Generics/Commission, C-601/16 P, EU:C:2021:244, paragraph 97).” (the underlining is ours).

The Constitutional Court, among others, in its Judgment STC 76/1999, has declared that administrative sanctions share the same nature as criminal ones, being one of the manifestations of the State's *ius puniendi*, and that, as a requirement derived from the principles of legal certainty and criminal legality enshrined in Articles 9.3 and 25.1 of the Constitution, their existence is essential for imposing them.

Regarding the culpability of legal entities, it is appropriate to cite Judgment STC 246/1991, December 19, 1991 (F.J. 2), according to which, concerning legal entities, the subjective element of culpability must necessarily be applied differently than it is for natural persons and adds that “This different construction of the attribution of the authorship of the infringement to the legal entity arises from the very nature of the legal fiction to which these subjects respond. They lack the volitional element in the strict sense, but not the capacity to infringe the norms to which they are subject. The capacity to infringe and, therefore, direct reproachability that derives from the legal good protected by the norm that is infringed and the necessity for that protection to be genuinely effective [...]”.

The respondent has invoked various arguments to justify the absence of culpability of their conduct. The decision to archive a sanctioning file may be based on the absence of the element of culpability when the responsible party for the unlawful conduct acted with all the diligence that the circumstances of the case require.

In compliance with the principle of culpability, the AEPD has agreed on numerous occasions to archive sanctioning procedures in which the element of culpability was not present.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/22

element of the culpability of the infringing subject. Situations in which, despite the existence of unlawful behavior, it had been established that the responsible party had acted with all the diligence that was required, and therefore no culpability was perceived in their conduct. This has been the criterion maintained by the Administrative Litigation Chamber, Section 1, of the National Court. The following rulings can be cited as particularly enlightening:

- SAN of April 26, 2002 (Rec. 895/2009) states:

“Indeed, one cannot affirm the existence of culpability based on the outcome, and this is what the Agency does by asserting that the result exists due to the failure to prevent it with security measures. Far from this, what should be done, and what is lacking in the Resolution, is to analyze the sufficiency of the measures from the parameters of average diligence required in the data traffic market. For if one acts with full diligence, scrupulously fulfilling the duties derived from diligent action, one cannot affirm or presume the existence of any culpability.”

- SAN of April 29, 2010, Legal Basis six, which, regarding fraudulent contracting, indicates that “The issue is not to determine whether the appellant processed the personal data of the complainant without their consent, but whether they exercised reasonable diligence when trying to identify the person with whom they entered into the contract.”

At this point, it is worth recalling once again what the STC 246/1991 has stated regarding the culpability of legal entities: that they do not lack the “capacity to infringe the norms to which they are subject.” “Capacity for infringement [...] that derives from the legal good protected by the norm that is infringed and the necessity for that protection to be truly effective [...]”.

In connection with the above, reference must be made to Article 5.2 of the GDPR (principle of proactive responsibility), according to which the data controller shall be responsible for compliance with the provisions of paragraph 1—concerning the principle of lawfulness in relation to Article 6.1 of the GDPR—and capable of demonstrating such compliance. The principle of proactivity transfers to the data controller the obligation not only to comply with the regulations but also to be able to demonstrate such compliance.

The Opinion 3/2010, from the Article 29 Working Party (WP29) -WP 173- issued during the validity of

the repealed Directive 95/46/EC, but whose reflections are applicable today, states that the “essence” of proactive responsibility is the obligation of the data controller to apply measures that, under normal circumstances, ensure that the data protection regulations are complied with in the context of processing operations and to have available documents that demonstrate to the data subjects and the supervisory authorities what measures have been adopted to achieve compliance with data protection regulations.

Article 5.2 is developed in Article 24 of the GDPR, which obliges the controller to adopt appropriate technical and organizational measures “to ensure and be able to demonstrate” that the processing is in compliance with the GDPR. The provision establishes:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/22

“Responsibility of the Data Controller”

“1. Taking into account the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the data controller shall implement appropriate technical and organizational measures to ensure and be able to demonstrate that the processing is in compliance with this Regulation. Such measures shall be reviewed and updated as necessary.

2. When provided in relation to the processing activities, among the measures mentioned in paragraph 1, the data controller shall include the implementation of appropriate data protection policies.

3. Adherence to approved codes of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may be used as elements to demonstrate compliance with the obligations of the data controller.”

Article 25 of the GDPR, “Data Protection by Design and by Default,” establishes:

“1. Taking into account the state of the art, the cost of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity that the processing entails for the rights and freedoms of natural persons, the data controller shall implement, both at the time of determining the means of processing and at the time of the processing itself, appropriate technical and organizational measures, such as pseudonymization, designed to effectively apply the principles of data protection, such as data minimization, and to integrate the necessary safeguards into the processing, in order to meet the requirements of this Regulation and protect the rights of the data subjects.

2. [...]”.

The ruling SAN of October 17, 2007 (rec. 63/2006) is fully applicable to the case, which, after referring to the fact that entities whose activities involve continuous processing of data from customers and third parties must observe an adequate level of diligence, states: “[...] the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the offender does not act with the required diligence. In assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard.”

Telefónica cites in its defense a series of resolutions issued by the AEPD, stating that in case EXP20210446, it was archived as it was understood that there was already an ongoing sanctioning file for the same facts and that Telefónica has already been sanctioned for the same facts that are currently being developed in this procedure, the Agency imposed the sanction through the procedure with reference PS/00021/2021 and therefore violates the principle of non bis in idem.

On this particular matter, it is important to highlight that these procedures aimed to analyze the processes followed to manage SIM change requests.

C/ Jorge Juan, 6

www.aepd.es

by Telefónica, identifying the vulnerabilities that may exist in the operational procedures implemented, to detect the causes for which these cases may be occurring, as well as to find points of non-compliance, improvement, or adjustment, to determine responsibilities, reduce risks, and enhance the security in the processing of personal data of the affected individuals.

In the sanctioning procedure PS/00021/2021, processed against the accused party, the violation of Article 5.1(f) was imputed; fraud and the processing of data without legitimacy were not imputed, but rather a lack of guarantees of the security measures that results in the transfer of data to a third party. Furthermore, regarding the fact that this Agency archived other similar complaints, it must be stated that these were archived, but always without prejudice to the Agency, applying the investigative and corrective powers it holds, being able to carry out subsequent actions related to data processing as indicated in the invoked resolutions.

Finally, the accused party states that the sanction violates the principle of proportionality.

On this particular matter, it should be recalled that Article 83.1 of the GDPR provides that “Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 5, and 6 are, in each individual case, effective, proportionate, and dissuasive.”

The fines, therefore, as deduced from the provision, must be effective, proportionate, and dissuasive for achieving the purpose intended by the GDPR. The amount to which the sanction for the infringement of Article 6.1 of the GDPR may ascend, in accordance with Article 83.5 of the GDPR, is “€20,000,000 at most or, in the case of an undertaking, an amount equivalent to 4% at most of the total global annual turnover of the previous financial year, opting for the higher amount.” Therefore, regardless of the above, the fine imposed on the accused party for the infringement of Article 6 of the GDPR is not disproportionate, since even if only the turnover of Telefónica were considered (according to the report collected from the AXESOR tool, its turnover is €4,406,624,000 in the year 2022), the sanction does not exceed €20,000,000 nor does it reach 4% of the total annual turnover of the previous financial year, in the terms of Article 83.4 of the GDPR.

For the reasons stated, the allegations presented against the initiation agreement are not accepted.

IV

Obligation Not Fulfilled

It is necessary to point out that Article 4.1 of the GDPR defines: “personal data” as “any information relating to an identified or identifiable natural person (‘the data subject’); an identifiable natural person is one who can be identified, directly or indirectly, in particular by reference to an identifier,

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/22

such as a name, an identification number, location data, an online identifier, or one or several elements specific to the physical, physiological, genetic, psychological, economic, cultural, or social identity of that person;”

In this regard, it is important to clarify that the SIM card is inserted within the mobile terminal. It is a smart card, in physical format and of small dimensions, which contains a chip where the service key of the subscriber is stored, used to identify themselves to the network, that is, the mobile phone line number of the customer MSISDN (Mobile Station Integrated Services Digital Network), as well as the personal identification number of the subscriber IMSI (International Mobile Subscriber Identity), but it can also provide other types of data such as information about the telephone directory or the list of calls and messages.

On the other hand, the issuance of a duplicate SIM card involves the processing of the personal data of its holder since any person whose identity can be determined, directly or indirectly, in particular by means of an identifier (Article 4.1) of the GDPR, will be considered an identifiable natural person.

Therefore, the SIM card identifies a phone number, and this number, in turn, identifies its holder. In this sense, the Judgment of the CJEU in Case C-101/2001 (Lindqvist) of November 6, 2003, paragraph 24, Rec. 2003 p. I-12971: "The concept of 'personal data' used in Article 3(1) of Directive 95/46 includes, according to the definition in Article 2(a) of that Directive, 'any information relating to an identified or identifiable natural person'. This concept undoubtedly includes a person's name along with their phone number or other information relating to their working conditions or hobbies."

In summary, both the data processed to issue a duplicate SIM card and the SIM card (Subscriber Identity Module) that unequivocally identifies the subscriber on the network are personal data, and their processing must be subject to data protection regulations.

Well, the respondent is accused of committing an infringement for violating Article 6 of the GDPR, "Lawfulness of processing," which states in its paragraph 1 the circumstances under which the processing of third-party data is considered lawful:

"1. Processing shall be lawful only if at least one of the following applies:

- a) the data subject has given consent to the processing of their personal data for one or more specific purposes;
- b) processing is necessary for the performance of a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract;
- c) processing is necessary for compliance with a legal obligation to which the controller is subject;
- d) processing is necessary to protect the vital interests of the data subject or of another natural person;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

17/22

e) the processing is necessary for the performance of a task carried out in the public interest or in the exercise of official authority vested in the data controller;

f) the processing is necessary for the purposes of legitimate interests pursued by the data controller or by a third party, provided that such interests do not override the interests or fundamental rights and freedoms of the data subject which require the protection of personal data, particularly when the data subject is a child. The provisions of item f) of the first paragraph shall not apply to processing carried out by public authorities in the exercise of their functions.

In the present case, it is established that "TME" provided a duplicate of the claimant's SIM card to a third party, without their consent and without verifying the identity of that third party, who accessed the information contained in the mobile phone. Thus, the defendant did not verify the identity of the person who requested the duplicate SIM card and did not take the necessary precautions to prevent these events from occurring.

Based on the above, in the analyzed case, the diligence employed by the defendant to identify the person who requested a duplicate of the SIM card is called into question.

Firstly, it should be noted, as "TME" acknowledges in its response to the transfer of the complaint dated June 16, 2023, that "TME" reports that there was a request for an ICC change of the claimant's SIM card on January 7, 2023, at 17:53 hours through a Telefónica Point of Sale, and indicates that the incident raised by the claimant arises from a fraudulent act committed maliciously by a third party with the intent to unlawfully profit at the expense of the claimant.

Secondly, in its response dated August 29, 2023, the defendant acknowledges that a fraudulent duplicate was issued, stating that upon reviewing its systems, "there is no documentation stored for the request for ICC change dated January 7, 2023."

In any case, the operator acknowledges that it did not follow the procedure implemented by itself, since, had it done so, the duplicate SIM card should have been denied.

In light of the above, the defendant fails to demonstrate that this procedure was followed.

It should be noted that SIM Swapping is a fraud that allows identity theft by hijacking the phone

number through obtaining a duplicate of the SIM card.

The result was that the defendant issued the SIM card to a third party who was not the owner of the line, although the impersonator knew the claimant's credentials, there were irregularities on the part of the operator, who delivered the SIM at a point of sale to a third party, as "TME" acknowledges. Furthermore, they do not provide the documentation for the ICC change request dated January 7, 2023.

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

18/22

Based on the above, in the analyzed case, the diligence employed by the defendant to identify the person who requested a duplicate of the SIM card is called into question.

In this regard, Recital 40 of the GDPR states:

"(40) For processing to be lawful, personal data must be processed with the consent of the data subject or on another legitimate basis established by law, whether in this Regulation or under another Union or Member State law to which this Regulation relates, including the necessity of complying with a legal obligation to which the data controller is subject or the necessity of performing a contract to which the data subject is party or in order to take steps at the request of the data subject prior to entering into a contract."

In accordance with the available evidence, it is estimated that the conduct of the defendant violates Article 6.1 of the GDPR, constituting an infringement as defined in Article 83.5.a) of the aforementioned Regulation 2016/679.

V

Classification and qualification of the infringement

The infringement is classified under Article 83.5 of the GDPR, which considers as such:

"Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an undertaking, an amount equivalent to 4% of the total annual global turnover of the preceding financial year, whichever is higher:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9."

The LOPGD, for the purposes of the prescription of the infringement, qualifies in its Article 72.1 as a very serious infringement, with a prescription period of three years in this case, b) "The processing of personal data without any of the conditions for lawful processing established in Article 6 of Regulation (EU) 2016/679."

VI

Sanction

The determination of the sanction to be imposed in the present case requires observing the provisions of Articles 83.1 and 2 of the GDPR, which respectively state the following:

"1. Each supervisory authority shall ensure that the imposition of administrative fines under this Article for the infringements of this Regulation referred to in paragraphs 4, 9, and 6 are, in each individual case, effective, proportionate, and dissuasive."

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es

19/22

"2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure for those contemplated in Article 58, paragraph 2, letters a) to h) and j). In deciding the imposition of an administrative fine and its amount in each individual case, the

following shall be duly taken into account:

- a) the nature, seriousness, and duration of the infringement, taking into account the nature, scope, or purpose of the processing operation in question, as well as the number of affected parties and the level of damage and harm they have suffered;
- b) the intent or negligence in the infringement;
- c) any measures taken by the data controller or processor to mitigate the damage and harm suffered by the affected parties;
- d) the degree of responsibility of the data controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;
- e) any prior infringement committed by the data controller or processor;
- f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;
- g) the categories of personal data affected by the infringement;
- h) the manner in which the supervisory authority became aware of the infringement, in particular whether the data controller or processor notified the infringement and, if so, to what extent;
- i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the data controller or processor in relation to the same matter, compliance with such measures;
- j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42, and
- k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

Within this section, the LOPDGDD provides in its Article 76, titled “Sanctions and corrective measures”:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

“2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

- a) The continued nature of the infringement.
- b) The connection of the infringer's activity with the processing of personal data.
- c) The benefits obtained as a result of the commission of the infringement.
- d) The possibility that the conduct of the affected party may have induced the commission of the infringement.
- e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.
- f) The impact on the rights of minors.
- g) Having, when not mandatory, a data protection officer.
- h) The voluntary submission by the data controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any affected party.”

It should be noted that the party being claimed has acted with a serious lack of diligence in the processing carried out in the course of its business activity. Regarding the degree of diligence that it is obliged to exercise in compliance with data protection regulations, it is worth citing the SAN of 17/10/2007 (rec. 63/2006), which, despite having been issued under the previous regulations, is fully applicable. It states that “[...] the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And the assessment of the degree of diligence must particularly weigh the professionalism or lack thereof of the subject, [...]”

Furthermore, in accordance with Article 83.1 of the GDPR, the imposition of fines is governed by the following principles: they must be individualized for each particular case, be effective, proportionate, and dissuasive.

The admission that it operates as a mitigating factor that the party being claimed has effectively resolved the incident subject to the claim partially nullifies the dissuasive purpose that is fulfilled

through the sanction. Accepting the thesis of “TME” in a case like the one at hand would imply introducing an artificial reduction in the sanction that should truly be imposed; the one that results from considering the circumstances of Article 83.2 GDPR that must indeed be assessed.

In order to determine the amount of the fine proposed to be imposed on “TME” for the infringement of Article 6.1 of the GDPR, we believe that the circumstances to which we will refer below, which operate as aggravating factors, are present.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

21/22

Thus, in accordance with paragraph e) of Article 83.2 of the GDPR, in determining the amount of the administrative fine, all previous infringements of the data controller or the data processor must be assessed in order to gauge the unlawfulness of the analyzed conduct or the culpability of the infringing party.

Furthermore, a correct interpretation of the provision of Article 83.2.e) of the GDPR cannot overlook the purpose pursued by the regulation: to decide the amount of the administrative fine in the individual case presented, always ensuring that the sanction is proportional, effective, and dissuasive.

There are numerous sanctioning procedures processed by the AEPD in which the respondent has been sanctioned for the infringement of Article 6.1 of the GDPR:

i. EXP 202209359. Resolution issued on June 16, 2023, in which a fine of 70,000 euros was imposed. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

ii. EXP 202211479. Resolution issued on June 13, 2023, in which a fine of 70,000 euros was imposed. The facts concerned a fraudulent duplicate of the SIM card without legitimacy.

- The evident link between the business activity of the respondent and the processing of personal data of clients or third parties (Article 83.2.k of the GDPR in relation to Article 76.2.b of the LOPDGDD).

The Judgment of the National Court of October 17, 2007 (rec. 63/2006), regarding entities whose activity involves continuous processing of customer data, indicates that “...the Supreme Court has understood that there is negligence whenever a legal duty of care is neglected, that is, when the infringer does not behave with the required diligence. In assessing the degree of diligence, special consideration must be given to the professionalism or lack thereof of the subject, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted upon the rigor and exquisite care to comply with the legal provisions in this regard.”

It is appropriate to graduate the sanction to be imposed on the respondent and set it at the amount of €200,000 for the alleged infringement of Article 6.1) classified in Article 83.5.a) of the aforementioned GDPR.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established, the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on TELEFÓNICA MÓVILES ESPAÑA, S.A.U., with NIF A78923125, for an infringement of Article 6.1 of the GDPR, classified in Article 83.5 of the GDPR, a fine of 200,000 euros (two hundred thousand euros).

SECOND: TO NOTIFY this resolution to TELEFÓNICA MÓVILES ESPAÑA, S.A.U.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

22/22

THIRD: To inform the sanctioned party that they must fulfill the imposed sanction once this resolution becomes executive, in accordance with the provisions of art. 98.1.b) of the LPACAP, within the voluntary payment period established in art. 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to art. 62 of Law 58/2003, of December 17, by making a

payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account no. IBAN: ES00 0000 0000 0000 0000 0000 (BIC/SWIFT Code: XXXXXXXXXXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A.

Otherwise, collection will proceed in the executive period.

Upon receiving the notification and once it is executive, if the date of executivity falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with art. 48.6 of the LOPDGDD, and in accordance with the provisions of article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of article 25 and section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of art. 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency [<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in art. 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not become aware of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es